



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Scattered Spider Threat Actor Profile

Threat Actor Profile

Classification	TLP:CLEAR
Published	2026-06-24
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Actor Profile

TLP:CLEAR | Lost Boys Cyber | Scattered Spider Threat Actor Profile - Threat Actor Profile

Published: 2026-06-24 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
 - 6.1. Sigma: Suspicious RMM or Tunnel Tool Execution
 - 6.2. KQL: MFA Reset Followed by Risky Sign-In or New Device
 - 6.3. KQL: Temporary Access Pass or MFA Method Abuse by Privileged Accounts
 - 6.4. KQL: Exchange Mail Rules Hiding Security Notifications
 - 6.5. KQL: SaaS and Collaboration Search for Incident Response Terms
 - 6.6. SPL: VMware vCenter / ESXi Suspicious Administrative Activity
 - 6.7. KQL: AWS S3 Enumeration and Potential Exfiltration
 - 6.8. KQL: Process and Network Indicators for Archive Staging and Cloud Exfiltration
 - 6.9. Okta System Log Hunt: MFA Factor Reset and Suspicious Help-Desk Pattern
 - 6.10. Emulation Plan for Purple-Team Validation
7. Recommendations
8. References

1. Executive Summary

Field	Assessment
Report Family	Threat Actor Profile
Subject	Scattered Spider, also tracked as UNC3944, Octo Tempest, Muddled Libra, Scatter Swine, Roasted Oktapus, and Storm-0875
Primary Motivation	Financially motivated extortion, data theft, ransomware deployment, and credential monetization
Primary Operating Model	Identity-first intrusion operations using social engineering against help desks, MFA reset workflows, SSO tenants, SaaS platforms, cloud resources, VMware infrastructure, and privileged access paths
Current Defensive Priority	Harden identity recovery and help-desk workflows, monitor cloud/SaaS control planes, and instrument VMware/vCenter/ESXi telemetry before ransomware deployment
Analyst Confidence	High for core TTPs and defensive actions; Moderate for actor membership boundaries and affiliate relationships because public reporting uses overlapping names and the group adapts rapidly

Scattered Spider is a financially motivated cybercriminal intrusion cluster best understood as an identity and social-engineering specialist rather than a traditional malware-first ransomware crew. The actor routinely obtains initial access through voice phishing, SMS phishing, MFA fatigue, SIM swapping, adversary-in-the-middle credential collection, and help-desk impersonation. Once inside, the operators pivot through Microsoft Entra ID, Okta, VPN, VDI, SaaS, PAM, email, cloud storage, and VMware environments to find credentials, response plans, sensitive data, and ransomware deployment opportunities.

The most consequential 2025 development is the actor's continued shift from credential theft and SaaS intrusion toward rapid sector-focused extortion operations involving insurance, retail, aviation, commercial facilities, VMware vCenter/ESXi environments, and ransomware variants including DragonForce. Public advisories from CISA/FBI and partner agencies describe Scattered Spider activity through June 2025, including data theft, legitimate tunneling/RMM abuse, and encryption of VMware ESXi servers. CrowdStrike reporting in July 2025 separately described Q2 2025 activity against aviation, insurance, and retail entities and emphasized help-desk voice phishing against Entra ID, SSO, and VDI accounts.

For defenders, Scattered Spider creates risk where identity recovery workflows are trusted more than device posture, where help desks can reset MFA without strong out-of-band verification, where SaaS and cloud telemetry is not retained, and where VMware management planes lack detection for rogue VM creation, disk attachment, SSH enablement, or ESXi ransomware staging. This profile prioritizes detection and hunting content around those control points because they are more durable than hash- or domain-only indicators.

2. Intelligence Requirement

Requirement	Answered In This Report	Defensive Decision Supported
What is Scattered Spider and how should leadership characterize the threat?	Sections 1, 4, and 5	Risk framing, sector exposure, identity/security investment
Which TTPs are most consistently associated with Scattered Spider?	Sections 4 and 5	Detection engineering backlog, control validation, ATT&CK mapping
What telemetry should defenders prioritize?	Section 6	SIEM onboarding, EDR/SaaS/cloud logging, VMware monitoring

What queries and detections can be adapted now?	Section 6	Hunt package, alert tuning, identity incident triage
How can the activity be safely emulated for readiness testing?	Section 6	Purple-team planning, tabletop exercises, SOC validation
What mitigations should be implemented first?	Section 7	Executive action plan and control owners

Scope assumptions: this profile is based on public reporting available to Lost Boys Cyber at report time, local source review, and defensive synthesis. It does not claim exclusive attribution for every campaign publicly associated with Scattered Spider aliases because multiple vendors define overlapping clusters differently. Where a behavior is described as actor-associated, the confidence is based on repeated reporting across CISA/FBI, MITRE ATT&CK, Google/Mandiant, Microsoft, CrowdStrike, HC3, Okta, and related public sources.

3. Source Review and Confidence

Source	Relevance	Confidence Contribution	Notes
CISA/FBI joint advisory AA23-320A, updated July 2025	Authoritative government TTP and mitigation baseline	High	Includes actor behavior through FBI investigations as recently as June 2025, updated ransomware and DragonForce references, LOTL/RMM tooling, and mitigation guidance
FBI / IC3 July 2025 PDF advisory	Government dissemination of the same updated activity	High	Confirms help-desk targeting, MFA bypass, ransomware/extortion focus, and core defensive recommendations
MITRE ATT&CK Group G1015	Structured ATT&CK mapping	High	Provides technique IDs and actor-use summaries for identity, cloud, VMware, exfiltration, ransomware, proxy, and RMM behaviors
Google Cloud / Mandiant UNC3944 hardening guidance, May 2025	Operational defender guidance from frontline IR	High	Focuses on identity hardening, help-desk controls, privileged access, SaaS/cloud monitoring, and rapid containment
CrowdStrike July 2025 sector escalation reporting	Current sector and operational detail	Moderate-High	Describes Q2 2025 aviation, insurance, and retail targeting; vCenter/ESXi objectives; transport-rule abuse; S3 enumeration/exfiltration
Microsoft Octo Tempest reporting	Alias linkage and ransomware/extortion evolution	Moderate-High	Useful for understanding social engineering, SIM swapping, extortion, and ransomware affiliate behavior
HC3 October 2024 profile	Healthcare-sector summary and tool catalog	Moderate	Useful cross-check for healthcare exposure, aliases, tools, malware families, and

			campaign chronology
Vendor and open-source reporting	Contextual enrichment	Moderate	Used only where consistent with higher-confidence sources or clearly marked as contextual

Confidence judgments:

- High confidence: Scattered Spider relies heavily on social engineering, help-desk impersonation, MFA reset abuse, phishing, SIM swapping, legitimate remote access tooling, cloud/SaaS discovery, credential access, data theft, and extortion.
- High confidence: defenders should prioritize phishing-resistant MFA, help-desk identity verification, SaaS/cloud log retention, application control, RMM allowlisting, and VMware/vCenter/ESXi monitoring.
- Moderate confidence: exact relationships among Scattered Spider, UNC3944, Octo Tempest, Muddled Libra, The Com, and ransomware affiliate structures vary by reporting source and should be treated as overlapping analytic labels rather than a single fixed legal entity.
- Moderate confidence: current ransomware branding changes rapidly; DragonForce, BlackCat/ALPHV, RansomHub, Qilin, and other payloads should be tracked as enabling infrastructure and affiliate relationships rather than the stable center of gravity.

4. Key Findings

ID	Finding	Impact	Confidence	Defensive Implication
F-01	Scattered Spider is identity-first and help-desk-centric. Operators often defeat controls by convincing staff to reset passwords, transfer MFA, approve prompts, or enroll new devices.	Compromise can occur without malware or exploit telemetry at the initial stage.	High	Treat identity recovery as a privileged workflow; monitor every MFA reset, device registration, temporary access pass, and help-desk override.
F-02	The actor pivots from SSO/VDI into SaaS, email, cloud storage, PAM, documentation, and collaboration tools.	Sensitive data and incident response plans may be exposed before endpoint alerts trigger.	High	Ingest Entra ID, Okta, M365, Google Workspace, Slack/Teams, PAM, VPN, VDI, AWS, Azure, and GCP logs into the SIEM.
F-03	VMware vCenter and ESXi infrastructure are high-value objectives for credential dumping, rogue VM creation, disk attachment, tunneling, and ransomware deployment.	Virtualized domain controllers and production workloads can be compromised or encrypted at scale.	High	Monitor vCenter events, ESXi shell/SSH, datastore access, new VMs, ISO uploads, disk attachment, snapshot activity, and administrative group changes.
F-04	The actor frequently uses legitimate RMM and tunneling tools such as AnyDesk, TeamViewer, ScreenConnect/Connect Wise, LogMeIn, ngrok,	Tool execution may blend into administrative traffic and bypass simplistic malware detections.	High	Enforce RMM allowlisting, alert on first-seen tools, and correlate RMM execution with identity anomalies and unusual

	Chisel, MobaXterm, Pinggy, rsocx, Teleport, and trycloudflare tunnels.			egress.
F-05	Email and collaboration systems are abused to hide compromise and monitor response. Public reporting includes mailbox searches for intrusion-response terms and transport/inbox rules to delete or redirect suspicious-account notices.	Incident responders may be watched, and warnings may be suppressed.	High	Hunt for mailbox searches, eDiscovery/export activity, suspicious forwarding rules, transport-rule changes, and security-notification deletion.
F-06	Data theft commonly precedes ransom pressure, and ransomware may be deployed after data exfiltration or when containment is delayed.	Organizations face double extortion even if encryption is prevented.	High	Prioritize exfiltration detection from cloud storage, SaaS export, S3 transfer, MEGA, Snowflake, and unusual archive staging.
F-07	Sector focus changes quickly. Recent public reporting emphasized commercial facilities, retail, insurance, aviation, healthcare, hospitality, telecom, technology, MSP, manufacturing, finance, and cryptocurrency-adjacent targets.	Organizations should not assume they are out of scope because the last public cluster targeted another sector.	Moderate-High	Monitor for sector copycat infrastructure and help-desk reconnaissance even when no malware indicators are present.
F-08	The actor's operational security is uneven, and arrests have occurred, but disruption has not eliminated the threat.	Overconfidence after law-enforcement action can create control gaps.	Moderate	Continue readiness validation against TTPs rather than actor-name news cycles.

5. Threat Context

Attribute	Details
Primary aliases	Scattered Spider, UNC3944, Octo Tempest, Muddled Libra, Scatter Swine, Roasted Oktapus, Storm-0875, Starfraud, LUCR-3, Oktapus, UNC3944-related clusters
ATT&CK group ID	G1015
Motivation	Financial gain through extortion, ransomware, payment diversion, credential theft, data theft, and monetization of privileged access
Initial-access pattern	Vishing, smishing, adversary-in-the-middle phishing, credential

	harvesting, SIM swapping, help-desk impersonation, MFA reset/social engineering, remote-access enrollment
Common targets	Help desks, privileged users, Entra ID/Okta tenants, VPN/VDI, PAM vaults, email, cloud storage, collaboration tools, Git/code repositories, VMware vCenter/ESXi, domain controllers
Common tools and malware	AnyDesk, TeamViewer, ScreenConnect/ConnectWise, LogMeIn, Splashtop, TacticalRMM, Level RMM, ngrok, Chisel, MobaXterm, Pinggy, rsocx, Teleport, ADEplorer, ADRecon.ps1, Get-ADUser, S3 Browser, Mimikatz, secretsdump, Raccoon Stealer, Vidar, Meduza/ULTRAKNOT, WarZone RAT, BlackCat/ALPHV, RansomHub, Qilin, DragonForce
Most durable detection surfaces	Identity audit logs, MFA/device enrollment logs, help-desk tickets/calls, RMM execution, proxy/tunnel egress, SaaS audit logs, mail rule changes, PAM access, cloud control-plane logs, vCenter/ESXi events

Scattered Spider operations usually begin before the technical intrusion is visible. Operators collect employee names, phone numbers, org charts, help-desk procedures, MFA enrollment instructions, VPN documentation, and prior breach data. That reconnaissance supports convincing impersonation of employees or IT staff. The actor can often answer help-desk verification questions because the answers are derived from public sources, previous breaches, internal SaaS data, or social-media collection.

A typical intrusion pattern is:

Stage	Activity	Observable Signals
Reconnaissance	Identify employees, help-desk workflows, SSO portals, vendors, VPN/VDI stack, phone numbers, and privileged users.	Lookalike domains, suspicious SMS campaigns, increased help-desk calls about resets, searches for company identity portals, external collection of employee details.
Initial Access	Vishing/smishing, adversary-in-the-middle login pages, MFA fatigue, SIM swap, help-desk password reset, MFA transfer, device registration, or remote-tool installation.	MFA method changes, temporary access passes, impossible travel, new device registration, suspicious RMM installation, help-desk reset ticket followed by high-risk sign-in.
Persistence	Enroll attacker-controlled MFA devices, create cloud accounts/roles, modify conditional access, deploy RMM/proxy/tunnel tools, abuse VPN/VDI sessions.	New authentication methods, new federated identity providers, trusted-location changes, first-seen RMM, ngrok/Cloudflare tunnel egress, unusual service creation.
Discovery	Search SaaS, SharePoint/OneDrive, Slack/Teams, email, PAM, code repositories, AWS/Azure/GCP, vCenter, AD, and documentation.	Bulk user/group downloads, Graph API enumeration, sensitive keyword searches, ADEplorer/ADRecon, S3 ListBuckets/ListObjects, vCenter inventory queries.

Credential Access	Dump NTDS.dit by attaching domain-controller disks to rogue VMs, access password vaults, use secretdump/Mimikatz, harvest browser/password-manager data.	Volume shadow copy, DC disk attachment, PAM vault access anomalies, LSASS access, DCSync, secretdump artifacts, abnormal privileged credential retrieval.
Collection and Exfiltration	Stage archives, export SaaS/cloud/email data, use MEGA/S3/Snowflake/remote storage, search IR communications.	Large downloads, unusual cloud storage writes, eDiscovery/export jobs, archive creation, abnormal outbound traffic, transport/inbox rules hiding security alerts.
Impact and Extortion	Deploy ransomware to ESXi or endpoints, inhibit recovery, threaten leak of stolen data, pressure executives and customers.	ESXi encryption, stopped backups/shadow copies, ransomware notes, mass file modification, disabled EDR/backup agents, extortion communications.

Indicators of Compromise and observable limitations:

Observable Class	Examples to Track	Confidence	Operational Guidance
Actor infrastructure	Lookalike SSO/help-desk domains, adversary-in-the-middle phishing portals, newly registered domains mimicking Okta/Entra/VPN portals	Moderate	Treat as campaign-scoped. Collect from email/SMS reports, proxy logs, brand monitoring, and domain-registration monitoring; do not rely on a static blocklist.
RMM and tunneling tools	AnyDesk, TeamViewer, ScreenConnect/ConnectWise, LogMeIn, Splashtop, TacticalRMM, Level RMM, ngrok, Chisel, Pinggy, rsocx, Teleport, MobaXterm, trycloudflare subdomains	High	These are dual-use tools. Alert on unauthorized execution, first-seen use, unmanaged hosts, unusual command lines, and identity anomalies rather than blocking every tool name blindly.
Cloud and SaaS behavior	S3 Browser use, ListBuckets/ListObjects bursts, unusual SharePoint/OneDrive downloads, mailbox searches, eDiscovery/export jobs, suspicious forwarding or deletion rules	High	These are behavioral IOCs/observables that should be converted into SIEM detections and hunts.
VMware behavior	Rogue VM creation, ISO upload, ESXi SSH/SFTP enablement, VMDK attachment, DC disk access, ESX Admins changes, datastore access anomalies	High	These observables are higher value than file hashes for Scattered Spider-style VMware intrusion paths.
Malware/ransomware family references	BlackCat/ALPHV, RansomHub, Qilin, DragonForce, infostealers such as Raccoon, Vidar, Meduza/ULTRAKNOT	Moderate-High	Track as payload/ecosystem indicators. Ransomware brand alone should not drive attribution; correlate with identity and VMware tradecraft.

MITRE ATT&CK mapping for prioritized defensive coverage:

Tactic	Technique	Scattered Spider Use	Priority
--------	-----------	----------------------	----------

Reconnaissance	T1589 Gather Victim Identity Information	Collect employee data and breach-derived identity details for impersonation.	High
Resource Development	T1583.001 Acquire Infrastructure: Domains	Register lookalike SSO and corporate login domains.	Medium
Initial Access	T1566.004 Phishing: Spearphishing Voice	Use phone calls to help desks and employees to reset credentials or direct RMM use.	Critical
Initial Access	T1190 Exploit Public-Facing Application	Historical exploitation such as ForgeRock OpenAM in reported campaigns.	Medium
Initial Access / Persistence	T1133 External Remote Services	Abuse VPN, Citrix, VDI, and remote services.	High
Credential Access / Persistence	T1556.006 Modify Authentication Process: MFA	Register attacker-controlled MFA tokens and alter authentication flows.	Critical
Credential Access	T1621 MFA Request Generation	Push bombing / MFA fatigue.	High
Defense Evasion	T1564.008 Hide Artifacts: Email Hiding Rules	Create mail rules to hide security alerts.	High
Defense Evasion	T1685 Disable or Modify Tools	Disable security tools and recovery services.	High
Discovery	T1087 Account Discovery	Enumerate domain, cloud, and email accounts.	High
Discovery	T1580 Cloud Infrastructure Discovery	Enumerate AWS/Azure/GCP resources and storage.	High
Discovery	T1069 Permission Groups Discovery	Enumerate AD/vSphere/ESX admin groups.	High
Credential Access	T1003.003 OS Credential Dumping: NTDS	Extract NTDS.dit using shadow copies or VM disk access.	Critical
Collection	T1213 Data from Information Repositories	Search SharePoint, code repositories, Slack/Teams, documentation.	High
Collection	T1114 Email Collection	Search Exchange/M365 mailboxes for sensitive and IR-related content.	High
Command and Control	T1572 Protocol Tunneling	Use Teleport, Chisel, ngrok, Pinggy, rsocx, Cloudflare tunnels.	High
Command and Control	T1090 Proxy	Use proxy networks and reverse	Medium-High

		proxy tools to obscure origin.	
Exfiltration	T1567.002 Exfiltration to Cloud Storage	Exfiltrate to MEGA, AWS S3, Snowflake, or other cloud storage.	High
Impact	T1486 Data Encrypted for Impact	Deploy ransomware including BlackCat and DragonForce; target VMware ESXi.	Critical
Impact	T1490 Inhibit System Recovery	Stop Volume Shadow Copy and impair backup/recovery.	High
Impact	T1657 Financial Theft	Monetize access through extortion, ransomware, and payment diversion.	High

6. Detection and Hunting

Detection strategy should be layered around identity, help-desk workflows, SaaS/cloud control planes, RMM/tunnel execution, VMware management, and exfiltration. Do not wait for malware indicators. The most reliable early signals are administrative identity changes shortly after a help-desk interaction, risky sign-in, new device registration, or RMM installation.

Coverage Area	Data Sources	Detection Objective	Priority
Help-desk reset abuse	ITSM tickets, call logs, Entra ID/Okta audit logs, MFA logs	Correlate password/MFA reset tickets with high-risk sign-ins, new devices, temporary access passes, or privileged activity.	Critical
MFA and authentication changes	Entra ID AuditLogs, SigninLogs, Okta System Log, Duo logs	Detect new MFA methods, MFA method deletion, TAP creation, SIM/SMS fallback, impossible travel, risky sign-in after reset.	Critical
SSO and conditional access abuse	Entra ID, Okta, IdP config audit	Detect trusted location additions, federated IdP changes, automatic account linking, admin role assignment, CA policy edits.	Critical
RMM/proxy/tunnel use	EDR process, DNS, proxy, firewall, network flow	Detect first-seen or unauthorized AnyDesk, TeamViewer, ScreenConnect, LogMeIn, ngrok, Chisel, Pinggy, MobaXterm, rsocx, Teleport, trycloudflare egress.	High
SaaS/email hiding and response monitoring	M365 Unified Audit Log, Exchange Admin Audit, Google Workspace, Slack/Teams audit	Detect mailbox searches for IR terms, email deletion, forwarding or transport rules, eDiscovery/export jobs, collaboration searches.	High
Cloud discovery and	AWS CloudTrail, Azure	Detect S3	High

exfiltration	Activity, GCP Audit, CASB	ListBuckets/ListObjects bursts, unusual cloud storage writes, cloud VM creation, IAM role changes, data export.	
VMware/vCenter/ESXi compromise	vCenter Events, ESXi auth/syslog, EDR on management hosts, network logs	Detect new VMs, ISO uploads, VMDK attachment, DC disk access, SSH/SFTP enablement, ESX Admins changes, encryption staging.	Critical
Credential dumping	EDR, Windows Security, Sysmon, vCenter, backup logs	Detect NTDS.dit access, shadow copy creation, DCSync, secretdump/Mimikatz, DC disk clone/attachment.	Critical
Data staging/exfiltration	EDR, proxy, DNS, CASB, DLP, object storage logs	Detect archive staging, MEGA/S3/Snowflake uploads, unusual compression, high-volume egress.	High

6.1. Sigma: Suspicious RMM or Tunnel Tool Execution

```

title: Scattered Spider Style RMM Or Tunnel Tool Execution
id: 4b8b36fb-9fd5-4bc7-b2cb-scattered-spider-rmm-tunnel
status: experimental
description: Detects execution of remote management, tunneling, or proxy tools commonly reported in Scattered Spider intrusions. Tune against approved administrative tooling inventory.
author: Lost Boys Cyber
references:
  - https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-320a
  - https://attack.mitre.org/groups/G1015/
logsource:
  product: windows
  category: process_creation
detection:
  selection_image:
    Image|endswith:
      - '\\AnyDesk.exe'
      - '\\TeamViewer.exe'
      - '\\ScreenConnect.ClientService.exe'
      - '\\LogMeIn.exe'
      - '\\Splashtop.exe'
      - '\\ngrok.exe'
      - '\\chisel.exe'
      - '\\pinggy.exe'
      - '\\rsocx.exe'
      - '\\teleport.exe'
      - '\\tsh.exe'
      - '\\mobaxterm.exe'
  selection_cmd:
    CommandLine|contains:
      - 'trycloudflare.com'
      - 'ngrok http'
      - 'chisel client'
      - 'teleport start'
      - 'rsocx'
  condition: selection_image or selection_cmd
fields:
  - UtcTime
  - Computer
  - User
  - Image

```

```

- CommandLine
- ParentImage
- ParentCommandLine
falsepositives:
- Approved remote support sessions, engineering tunnels, or IT automation. Suppress only by signed
binary, managed host group, and change/ticket context.
level: high
tags:
- attack.t1219.002
- attack.t1572
- attack.t1090

```

6.2. KQL: MFA Reset Followed by Risky Sign-In or New Device

```

let lookback = 7d;
let reset_window = 12h;
let MfaOrPasswordChanges = AuditLogs
| where TimeGenerated > ago(lookback)
| where OperationName has_any ("Reset password", "Change password", "Update user", "User registered
security info", "Admin registered security info", "Add authentication method", "Delete authentication
method", "Create Temporary Access Pass")
| extend TargetUPN = tostring(TargetResources[0].userPrincipalName)
| extend Initiator = tostring(InitiatedBy.user.userPrincipalName)
| project ResetTime=TimeGenerated, TargetUPN, OperationName, Initiator, Result, CorrelationId;
let RiskyOrNewDeviceSignins = SigninLogs
| where TimeGenerated > ago(lookback)
| extend DeviceId = tostring(DeviceDetail.deviceId), DeviceName=tostring(DeviceDetail.displayName)
| where RiskLevelAggregated in ("medium", "high")
    or ResultType == 0 and isempty(DeviceId)
    or ConditionalAccessStatus =~ "notApplied"
| project SigninTime=TimeGenerated, UserPrincipalName, IPAddress, AppDisplayName, DeviceId, DeviceName,
Location, RiskLevelAggregated, ConditionalAccessStatus;
MfaOrPasswordChanges
| join kind=innerunique RiskyOrNewDeviceSignins on $left.TargetUPN == $right.UserPrincipalName
| where SigninTime between (ResetTime .. ResetTime + reset_window)
| project ResetTime, SigninTime, TargetUPN, OperationName, Initiator, IPAddress, Location,
AppDisplayName, DeviceId, DeviceName, RiskLevelAggregated, ConditionalAccessStatus
| order by ResetTime desc

```

Analyst use: prioritize hits where the reset was performed by help-desk staff, followed by privileged application access, new geography, unmanaged device, VPN/VDI sign-in, or SaaS export activity.

6.3. KQL: Temporary Access Pass or MFA Method Abuse by Privileged Accounts

```

let privileged_terms = dynamic(["Global Administrator", "Privileged Role Administrator", "User
Administrator", "Authentication Administrator", "Helpdesk Administrator"]);
let PrivilegedUsers = IdentityInfo
| where TimeGenerated > ago(14d)
| mv-expand AssignedRoles
| where tostring(AssignedRoles) has_any (privileged_terms)
| summarize by AccountUPN;
AuditLogs
| where TimeGenerated > ago(14d)
| where OperationName has_any ("Create Temporary Access Pass", "Add authentication method", "Delete
authentication method", "Update user", "Add member to role", "Add eligible member to role")
| extend TargetUPN=tostring(TargetResources[0].userPrincipalName),
Initiator=tostring(InitiatedBy.user.userPrincipalName)
| where TargetUPN in (PrivilegedUsers) or Initiator in (PrivilegedUsers)
| project TimeGenerated, OperationName, TargetUPN, Initiator, Result, TargetResources,
AdditionalDetails, CorrelationId
| order by TimeGenerated desc

```

6.4. KQL: Exchange Mail Rules Hiding Security Notifications

```

OfficeActivity
| where TimeGenerated > ago(30d)
| where Workload =~ "Exchange"
| where Operation in~ ("New-InboxRule", "Set-InboxRule", "New-TransportRule", "Set-TransportRule",

```

```
"Remove-InboxRule", "Remove-TransportRule")
| extend Params = toString(Parameters)
| where Params has_any ("delete", "redirect", "forward", "MoveToFolder", "security", "suspicious",
"MFA", "password", "Okta", "Microsoft", "Entra", "Duo", "CrowdStrike", "Defender", "alert")
| project TimeGenerated, UserId, Operation, ClientIP, ResultStatus, Params
| order by TimeGenerated desc
```

Analyst use: investigate any rule created by a newly reset user, help-desk-admin context, compromised security personnel mailbox, or account that also has risky sign-ins.

6.5. KQL: SaaS and Collaboration Search for Incident Response Terms

```
OfficeActivity
| where TimeGenerated > ago(14d)
| where Workload in~ ("Exchange", "SharePoint", "OneDrive", "MicrosoftTeams")
| where Operation has_any ("Search", "FileAccessed", "FileDownloaded", "MailItemsAccessed",
"MessageRead", "Export")
| extend Detail = strcat(toString(OfficeObjectId), " ", toString(SourceFileName), " ",
toString(Parameters))
| where Detail has_any ("incident response", "IR", "ransomware", "MFA reset", "VPN", "break glass",
"password vault", "backup", "EDR", "CrowdStrike", "Defender", "Okta", "Duo", "domain admin", "vCenter",
"ESXi")
| summarize Events=count(), FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated),
Samples=make_set(Detail, 10) by UserId, ClientIP, Operation, Workload
| order by Events desc
```

6.6. SPL: VMware vCenter / ESXi Suspicious Administrative Activity

```
index=vmware (sourcetype=vmware:events OR sourcetype=esx* OR sourcetype=vcenter*)
("VmCreatedEvent" OR "VmReconfiguredEvent" OR "DatastoreFileUploadEvent" OR "HostServiceStartedEvent"
OR "UserLoginSessionEvent" OR "esxcli" OR "SSH" OR "SFTP" OR "VMDK" OR "ntds.dit" OR "ESX Admins")
| eval risk_event=case(
    match(_raw,"(?i)DatastoreFileUploadEvent|iso"),"ISO or datastore upload",
    match(_raw,"(?i)VmCreatedEvent|created virtual machine"),"New VM created",
    match(_raw,"(?i)VMDK|disk attach|ntds\.dit"),"Sensitive disk attachment or NTDS access",
    match(_raw,"(?i)SSH|SFTP|HostServiceStartedEvent"),"Remote shell or file service enabled",
    match(_raw,"(?i)ESX Admins|vSphere Admin"),"Privileged VMware group change",
    true(),"Other VMware administrative event")
| stats count min(_time) as first_seen max(_time) as last_seen values(user) as users values(src_ip) as
src_ips values(host) as hosts values(risk_event) as risk_events values(_raw) as samples by risk_event
| convert ctime(first_seen) ctime(last_seen)
| sort - count
```

6.7. KQL: AWS S3 Enumeration and Potential Exfiltration

```
AWSCloudTrail
| where TimeGenerated > ago(14d)
| where EventName in ("ListBuckets", "ListObjects", "GetObject", "PutObject", "CreateBucket",
"PutBucketPolicy")
| summarize Events=count(), Buckets=make_set(toString(RequestParameters.bucketName), 25),
SourceIPs=make_set(SourceIpAddress, 25), UserAgents=make_set(UserAgent, 25),
FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated) by UserIdentityArn, EventName
| where Events > 50 or EventName in ("CreateBucket", "PutBucketPolicy")
| order by Events desc
```

Analyst use: correlate S3 Browser or unusual user agents with newly compromised identity, VPN/VDI access, and external destination buckets.

6.8. KQL: Process and Network Indicators for Archive Staging and Cloud Exfiltration

```
let suspicious_tools = dynamic(["7z.exe", "rar.exe", "WinRAR.exe", "rclone.exe", "megacmd.exe",
"MEGAsync.exe", "s3browser.exe", "aws.exe", "azcopy.exe"]);
let exfil_domains = dynamic(["mega.nz", "mega.co.nz", "amazonaws.com", "blob.core.windows.net",
"storage.googleapis.com", "trycloudflare.com", "ngrok.io", "ngrok-free.app"]);
DeviceProcessEvents
| where Timestamp > ago(14d)
| where FileName in~ (suspicious_tools)
    or ProcessCommandLine has_any (" a -", " -mx", "sync", "copy", "s3://", "mega", "azcopy", "--
recursive")
```

```

| project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, ProcessCommandLine,
InitiatingProcessFileName
| join kind=leftouter (
  DeviceNetworkEvents
  | where Timestamp > ago(14d)
  | where RemoteUrl has_any (exfil_domains)
  | project NetTime=Timestamp, DeviceName, RemoteUrl, RemoteIP, RemotePort, InitiatingProcessFileName
) on DeviceName
| where isnull(NetTime) or NetTime between (Timestamp .. Timestamp + 6h)
| order by Timestamp desc

```

6.9. Okta System Log Hunt: MFA Factor Reset and Suspicious Help-Desk Pattern

```

index=okta sourcetype=okta:im2 eventType IN
(user.mfa.factor.reset_all,user.mfa.factor.deactivate,user.mfa.factor.activate,user.account.reset_passw
ord,user.account.update_password,system.org.rate_limit.warning,policy.mfa.attempt_bypass)
| eval actor=actor.alternateId, target=target{}.alternateId, client_ip=client.ipAddress,
outcome=outcome.result
| stats count min(_time) as first_seen max(_time) as last_seen values(eventType) as events
values(actor) as actors values(client_ip) as client_ips values(client.geographicalContext.country) as
countries by target
| where count >= 2 OR mvcount(client_ips) > 1
| convert ctime(first_seen) ctime(last_seen)
| sort - count

```

6.10. Emulation Plan for Purple-Team Validation

This emulation guidance is designed for controlled internal validation only. Do not use real credential theft, SIM swapping, public phishing infrastructure, ransomware, or unauthorized SaaS access. Use test tenants, test accounts, approved tooling, and pre-briefed help-desk staff.

Emulation Phase	Safe Activity	Expected Detection	Success Criteria
Help-desk reset simulation	Create a test ticket requesting password reset and MFA re-enrollment for a seeded user.	Ticket + audit-log correlation alert.	SOC sees reset, new MFA method, and follow-on sign-in in one case.
MFA fatigue simulation	Generate repeated MFA prompts against a consenting test account or use IdP test logs.	Repeated denied/ignored MFA challenge detection.	Alert fires before approval and playbook directs help-desk verification.
RMM/tunnel control test	Execute approved test copies of AnyDesk/ngrok/chisel on a lab endpoint or generate telemetry-only events.	First-seen RMM/tunnel process and egress alert.	Alert includes host, user, command line, destination, and owner/ticket context.
SaaS discovery test	Use test account to download SharePoint/OneDrive docs with seeded keywords such as VPN, MFA, password vault, backup.	Sensitive repository search/download hunt.	Hunt returns user, files, IP, and timing.
Mail hiding-rule test	Create a benign inbox rule moving messages with a test keyword such as security-alert-test.	Inbox/transport rule detection.	Alert fires and includes rule action/keyword.
Cloud storage enumeration	Use a test AWS principal to ListBuckets/ListObjects at unusual volume.	CloudTrail S3 enumeration alert.	Alert fires with principal, source IP, bucket list, and user agent.

VMware administrative test	In lab vCenter, create a VM, upload an ISO, enable SSH, or attach a non-sensitive test disk.	VMware suspicious admin activity alert.	SIEM shows event sequence and correlates to admin identity.
Exfiltration simulation	Compress benign test data and upload to an approved internal S3 bucket or test MEGA-equivalent blocklisted domain sink.	Archive + outbound cloud upload correlation.	SOC receives staging and network alert without using real sensitive data.

7. Recommendations

Priority	Recommendation	Owner	Rationale	Verification
1	Enforce phishing-resistant MFA for privileged and high-risk users; remove SMS/voice as a recovery factor where possible.	Identity Engineering	Scattered Spider repeatedly targets MFA reset and SMS/SIM weaknesses.	Quarterly audit of MFA methods; exception list signed by risk owner.
1	Treat help-desk password/MFA reset as a privileged security workflow with callback validation, manager approval for privileged users, identity proofing, and no same-channel approval.	IT Operations / IAM	Help-desk impersonation is a core access path.	Red-team reset tests; random sample of reset tickets; alert correlation.
1	Centralize identity telemetry from Entra ID, Okta, Duo, VPN, VDI, PAM, and ITSM into SIEM with at least 180 days retention.	SOC / IAM	Early Scattered Spider activity may be visible only in identity and ticket logs.	Confirm query coverage and retention with monthly SIEM health checks.
1	Instrument VMware vCenter/ESXi logging and alert on new VMs, ISO uploads, SSH/SFTP enablement, disk attachment, ESX Admins changes, and datastore access.	Infrastructure / SOC	VMware management-plane compromise can lead to domain credential theft and ESXi ransomware.	Run emulation tests from Section 6.10 and verify alerts.
1	Maintain offline, immutable backups for identity systems, hypervisors, domain controllers, SaaS configuration exports, and critical business data.	Infrastructure / DR	Ransomware and recovery inhibition are observed impact paths.	Restore tests and backup isolation validation.
2	Implement RMM and	Endpoint / Network	The actor uses legitimate	Application control

	tunneling tool allowlisting. Block or require approval for AnyDesk, TeamViewer, ScreenConnect, LogMeIn, ngrok, Chisel, rsocx, Pinggy, Teleport, and similar tools unless business-owned.		tools to evade malware-centric controls.	policy review; first-seen tool alerting.
2	Monitor and restrict SaaS mailbox rules, transport rules, eDiscovery, data export, and collaboration searches by sensitive keywords.	Messaging / SOC	The actor hides alerts and searches for IR/security content.	Weekly hunt for suspicious rules and exports; privileged approvals.
2	Harden conditional access and device trust: require compliant devices, restrict trusted-location edits, alert on new federated IdP or automatic account-linking changes.	IAM	Actor-associated techniques include MFA token enrollment, CA changes, and IdP trust abuse.	Change-control review for policy edits; automated alerts.
2	Deploy PAM controls for help-desk/admin actions and separate break-glass accounts from daily-use accounts.	IAM / Security Architecture	Privileged reset and role-assignment abuse can accelerate compromise.	PAM access reviews and privileged role activation alerts.
2	Restrict cloud storage and object-store egress. Alert on S3 Browser, unusual ListBuckets/ListObjects, large object downloads, and external bucket writes.	Cloud / SOC	Cloud discovery and exfiltration are repeated actor behaviors.	CloudTrail/CASB detection tests.
3	Conduct quarterly Scattered Spider tabletop and purple-team exercises using the emulation plan in Section 6.10.	SOC / IR / IT Ops	The threat crosses people, process, identity, cloud, endpoint, and infrastructure.	After-action report with control fixes and detection gaps.
3	Build a sector-specific watchlist for lookalike identity domains, help-desk phone targeting, and vendor impersonation.	Threat Intel / SOC	Sector waves are rapid and can precede public reporting.	Brand/domain monitoring and phishing intake review.
3	Train help-desk and executive-support teams	Security Awareness / IT Ops	Human process is a primary attack surface.	Simulated calls and measured escalation

	on vishing escalation, deepfake/AI voice risk, MFA reset abuse, and safe refusal scripts.			behavior.
--	---	--	--	-----------

Immediate 30-day action plan:

- Inventory all MFA reset paths, temporary access pass permissions, help-desk override roles, and privileged recovery workflows.
- Disable SMS/voice MFA for admins and executives; migrate to FIDO2/WebAuthn or certificate-backed authentication where feasible.
- Onboard Entra ID/Okta/Duo, VPN, VDI, M365/Exchange, PAM, AWS/Azure/GCP, vCenter/ESXi, and ITSM logs into a unified detection workspace.
- Deploy the Section 6 hunts as scheduled queries or manual hunt packs and tune against known administration.
- Identify all approved RMM/tunneling tools and block or alert on unapproved equivalents.
- Validate backups for identity, virtualization, and business-critical SaaS/cloud data.

8. References

- [1] CISA, FBI, HHS, MS-ISAC, and international partners. “Scattered Spider,” Cybersecurity Advisory AA23-320A, originally November 16, 2023; updated July 29, 2025. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-320a>
- [2] FBI / IC3. “Product ID: AA23-320A Scattered Spider,” July 29, 2025 PDF advisory. <https://www.ic3.gov/CSA/2025/250729.pdf>
- [3] MITRE ATT&CK. “Scattered Spider, Roasted Oktapus, Octo Tempest, Storm-0875, UNC3944 — Group G1015.” <https://attack.mitre.org/groups/G1015/>
- [4] Google Cloud / Mandiant. “Defending Against UNC3944: Cybercrime Hardening Guidance from the Frontlines,” May 6, 2025. <https://cloud.google.com/blog/topics/threat-intelligence/unc3944-proactive-hardening-recommendations>
- [5] CrowdStrike. “CrowdStrike Services Observes SCATTERED SPIDER Escalate Attacks Across Industries,” July 2, 2025. <https://www.crowdstrike.com/en-us/blog/crowdstrike-services-observes-scattered-spider-escalate-attacks/>
- [6] Microsoft Security. “Octo Tempest crosses boundaries to facilitate extortion, encryption, and destruction,” October 25, 2023. <https://www.microsoft.com/en-us/security/blog/2023/10/25/octo-tempest-crosses-boundaries-to-facilitate-extortion-encryption-and-destruction/>
- [7] U.S. Department of Health and Human Services HC3. “TLP:CLEAR Threat Actor Profile: Scattered Spider,” October 24, 2024. <https://www.aha.org/system/files/media/file/2024/10/hc3+tlp+clear+threat+actor+profile+scattered+spider-10-24-2024.pdf>
- [8] Okta Security. “Detecting Scatter Swine: Insights into a Relentless Phishing Campaign,” August 25, 2022. <https://sec.okta.com/scatterswine>
- [9] Palo Alto Networks Unit 42. “Muddled Libra’s Evolution to the Cloud,” April 9, 2024. <https://unit42.paloaltonetworks.com/muddled-libra-cloud/>
- [10] CISA Alert. “CISA and Partners Release Updated Advisory on Scattered Spider Group,” July 29, 2025. <https://www.cisa.gov/news-events/alerts/2025/07/29/cisa-and-partners-release-updated-advisory-scattered-spider-group>
- [11] CrowdStrike Intelligence. “SCATTERED SPIDER Exploits Windows Security Deficiencies with Bring-Your-Own-Vulnerable-Driver Tactic in Attempt to Bypass Endpoint Security,” January 10, 2023. <https://www.crowdstrike.com/en-us/blog/scattered-spider-attempts-to-avoid-detection-with-bring-your-own-vulnerable-driver-tactic/>